SENTINEL 25-CONTROL PASSIVE EVALUATION SYSTEM — TECHNICAL ARCHITECTUR

100% Non-Intrusive External OSINT & Regulatory Compliance Engine (DNS-over-HTTPS + TLS + HTTP Header + DOM Inspection)

Open-Source Code & Methodology: https://github.com/kaledbouchagraoui7-bot/medtech-regulatory-compliance-suite | Author: Kaled Bouchagraoui

STAGE 1: PASSIVE COLLECTORS

- Cloudflare/Google DoH (TXT/MX/CAA)
- TLS 1.2/1.3 X.509 Handshake Check
- Single Standard HTTPS GET Request
- Zero port-scanning or active probing

STAGE 2: 25-CONTROL ENGINE

- Weighted 100-Point Scoring Matrix
- 5 Regulatory & Security Pillars
- Automated Evidence Extraction
- False-Positive Header Normalization

STAGE 3: CLINICAL & PMS ADD-ONS

- PRISMA 2020 Literature Synthesizer
- OpenFDA MAUDE + ClinicalTrials.gov
- EU MDR Annex XIV / CER / PSUR Tables
- Mathematical Conservation Checks

STAGE 4: TURNKEY DELIVERABLES

- 300-DPI Visual Scorecard (PNG/PDF)
- Landscape Executive Audit (.docx)
- 4-Sheet Filterable Matrix (.xlsx)
- Drop-in Nginx/Cloudflare/DNS Configs

COMPLETE 25-CONTROL EVALUATION MATRIX & INTERNATIONAL REGULATORY MAPPING

Pillar 1: Email Anti-Spoofing & Deliverability (Weight: 26 pts)

- EML-01 (12 pt): DMARC Record & Enforcement Policy (p=quarantine / p=reject vs missing or p=none) — RFC 7489 / Gmail & Yahoo Bulk Sender Rule
- EML-02 (8 pt): SPF (Sender Policy Framework) Syntax & Lookup Ceiling (<=10 lookups, -all / ~all) — RFC 7208
- EML-03 (3 pt): Inbound Mail Exchange (MX) Redundancy & Routing Integrity — RFC 5321
- EML-04 (3 pt): DNS CAA (Certificate Authority Authorization) Restriction — RFC 8659

Pillar 2: Web Privacy, Cross-Border Data & Consent Hygiene (Weight: 25 pts)

- PRV-01 (8 pt): Remote Google Fonts IP Leak Detection (fonts.googleapis.com / fonts.gstatic.com pre-consent transfer) — GDPR Art. 44 / Swiss nFADP
- PRV-02 (7 pt): Initial HTML Third-Party Advertising & Behavioral Tracker Inspection (GTM, GA, Meta, Hotjar, HubSpot) — ePrivacy / UK GDPR / CCPA
- PRV-03 (5 pt): Pre-Consent Cookie Hygiene & Security Flags (Secure, HttpOnly, SameSite attributes on initial response) — OWASP / GDPR Art. 25
- PRV-04 (5 pt): Discoverable Privacy Notice / Data Protection Policy Link on Landing Page — GDPR Art. 13 / Swiss nFADP Art. 19 / HIPAA

Pillar 3: Edge, Transport & Application Hardening (Weight: 27 pts)

- SEC-01 (8 pt): TLS 1.2/1.3 Encryption Protocol & X.509 Certificate Validity Horizon — OWASP Transport Layer Protection / EU MDR GSPR 17.2
- SEC-02 (7 pt): HTTP Strict-Transport-Security (HSTS max-age >= 15768000) — RFC 6797 | SEC-03 (7 pt): Content-Security-Policy (CSP XSS Defense)
- SEC-04 (5 pt): Clickjacking Protection (X-Frame-Options / frame-ancestors) | SEC-05 (4 pt): MIME-Sniffing Lock (X-Content-Type-Options: nosniff)
- SEC-06..09: Referrer-Policy, Permissions-Policy (Camera/Mic/Geo Lockdown), Server Version Suppression & RFC 9116 /.well-known/security.txt

Pillar 4: Accessibility (WCAG 2.1 AA / EAA / ADA) & Pillar 5: Technical Discoverability (Weight: 22 pts)

- ACC-01..04: HTML <html lang> declaration, Image alt-text coverage (>=90%), Form input <label>/aria-label binding, and Viewport zoom-lock check
- SEO-01..04: robots.txt availability, XML Sitemap declaration, Canonical URL normalization, and JSON-LD Schema.org structured metadata

TURNKEY REMEDIATION & VERIFICATION DELIVERABLES (FIXED B2B FEE: EUR 350 / USD 380 / GBP 300 / CHF 350)

1. Full Landscape Executive Word Audit (.docx) & 4-Sheet Filterable Technical Matrix (.xlsx) mapped to every failing and warning control.
2. Ready-to-deploy DNS TXT records (DMARC/SPF/CAA), Nginx/Apache/Cloudflare HTTP security header snippets, and local webfont privacy fixes.
3. Post-deployment re-verification scan & updated 300-DPI compliance certificate once your IT/web team applies the snippets.